

VULNERABILITY ASSESSMENT REPORT

ALTORO MUTUAL

EXECUTIVE SUMMARY

This report presents a basic vulnerability assessment of the Altoro Mutual demo banking website (demo.testfire.net). The assessment was conducted using a read-only and ethical approach, focusing on publicly accessible areas without performing any intrusive or harmful actions.

During the analysis, several common security weaknesses were identified, including missing security headers, potential cookie misconfigurations, and minor exposure of technical information. These issues do not immediately compromise the system but may increase the risk of attacks if left unaddressed.

Overall, the website demonstrates a moderate level of security risk. While it functions as intended, certain improvements are recommended to enhance protection, strengthen user data security, and align with standard web security practices.

SCOPE & OBJECTIVE

Scope:

- The assessment was conducted on the publicly accessible areas of the Altoro Mutual website (demo.testfire.net).
- Only client-side and openly available resources were reviewed.
- No authenticated or restricted sections were accessed.

Objective:

- To identify common security weaknesses using non-intrusive methods.
- To evaluate the website's security posture from an external user perspective.
- To provide clear and practical recommendations for improving security.

Testing Approach:

- Passive analysis techniques were used throughout the assessment.
- No exploitation, brute-force attempts, or harmful activities were performed.
- The testing strictly followed ethical guidelines and a read-only approach.

TOOLS USED

The following tools were used to perform a safe and non-intrusive vulnerability assessment:

- Nmap
- Used to identify open ports and analyze exposed network services.
- OWASP ZAP (Passive Scan)
- Used to detect common web vulnerabilities without performing active attacks.
- Browser Developer Tools (DevTools)
- Used to inspect cookies, headers, and client-side behavior directly from the browser.
- SecurityHeaders.com
- Used to evaluate the presence and effectiveness of HTTP security headers.

WEBSITE OVERVIEW

Website Name: Altoro Mutual

Website URL: <http://demo.testfire.net/>

Altoro Mutual is a demo online banking application created for security testing and educational purposes. The website simulates real-world banking functionalities such as account login, fund transfers, and customer services.

It is intentionally designed with known security weaknesses, making it a suitable target for vulnerability assessment practice. The platform provides a realistic environment to identify and analyze common web security issues in a safe and controlled manner.

For this assessment, only publicly accessible sections of the website were analyzed using passive and non-intrusive techniques.

Altoro Mutual

Sign In | Contact Us | Feedback | Search

DEMO SITE ONLY

ONLINE BANKING LOGIN

PERSONAL

- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS

- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

INSIDE ALTORO MUTUAL

- About Us
- Contact Us
- Locations
- Investor Relations
- Press Room
- Careers
- Subscribe

Online Banking with FREE Online Bill Pay

No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing

Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it.

Business Credit Cards

You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions

Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Privacy and Security

The 2000 employees of Altoro Mutual are dedicated to protecting your privacy and security. We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

Win a Samsung Galaxy S10 smartphone

Completing this short survey will enter you in a draw for 1 of 5 Samsung Galaxy S10 smartphones! We look forward to hearing your important feedback.

Privacy Policy | Security Statement | Server Status Check | REST API | © 2026 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The Altoro website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/aopscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2026, HCL Technologies, Ltd., All rights reserved.

MISSING SECURITY HEADERS

RISK LEVEL: MEDIUM

The security analysis of the target website reveals that several important HTTP security headers are missing. As shown in the screenshot, the website received a grade of F, indicating poor security configuration.

Critical headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy are not implemented. These headers play a key role in protecting the website from common web-based attacks by controlling how browsers handle content and enforce security rules.

The absence of these headers increases the exposure of the application to client-side attacks and reduces overall security posture.

Missing security headers can expose the website to various attacks such as cross-site scripting (XSS), clickjacking, and content-type spoofing. Attackers may exploit these weaknesses to inject malicious scripts, manipulate how the website is displayed, or steal sensitive user data.

Additionally, the lack of proper policies reduces control over browser behavior, making it easier for attackers to exploit client-side vulnerabilities.

It is recommended to implement standard HTTP security headers on the web server to enhance protection. The following headers should be properly configured:

- Content-Security-Policy (CSP): To prevent execution of unauthorized scripts
- X-Frame-Options: To protect against clickjacking attacks
- X-Content-Type-Options: To prevent MIME-type sniffing
- Referrer-Policy: To control information shared in HTTP referrer headers
- Permissions-Policy: To restrict access to browser features

These headers can be configured at the server level (e.g., Apache, Nginx) or within the application framework to significantly improve overall security.

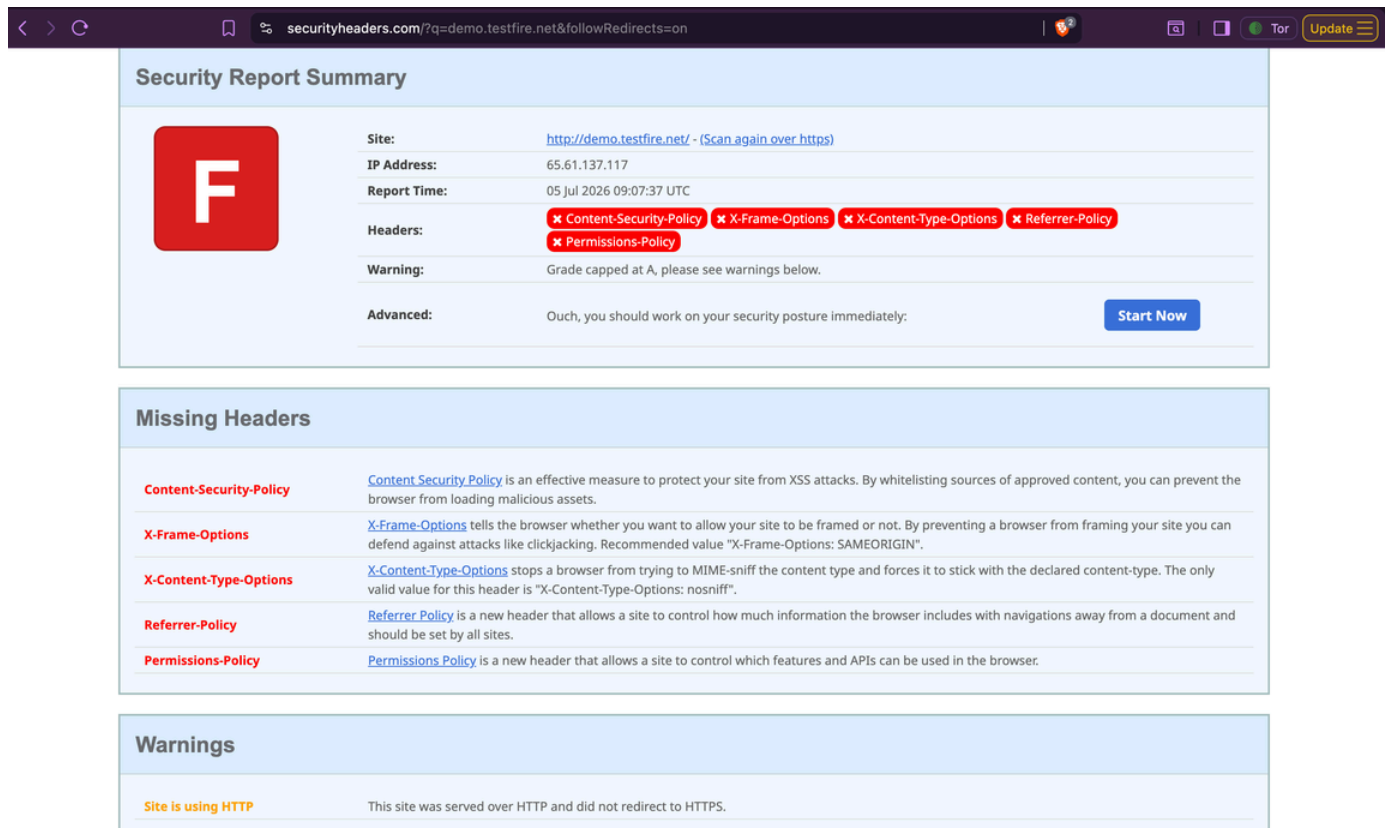


Figure : Security Headers Analysis

The screenshot shows the security headers evaluation of the target website, highlighting missing critical headers and an overall low security grade.

FINDING #2 – OPEN PORTS EXPOSURE

RISK LEVEL: LOW

```
user@laptop:~$ nmap -F demo.testfire.net

Starting Nmap 7.92 ( https://nmap.org ) at 2026-07-05 15:01 IST
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.045s latency).

PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 0.50 seconds
```

Figure : Nmap Scan Results

The screenshot shows the Nmap scan output identifying open ports and active services on the target server.

The network scan performed using Nmap identified that the target website has specific ports open and accessible over the internet. These ports are used to allow communication between the server and users.

As observed in the scan results, commonly used ports such as Port 80 (HTTP) are open, which is expected for a web application. However, open ports indicate exposed entry points that could potentially be targeted by attackers if not properly secured.

While no unusual or high-risk ports were identified in this case, the presence of open ports still represents a potential attack surface.

Open ports can provide attackers with information about the services running on a server. If these services are outdated, misconfigured, or vulnerable, they may be exploited to gain unauthorized access or disrupt operations.

Even standard ports like HTTP (Port 80) can pose risks if secure configurations such as HTTPS are not enforced. This increases the possibility of data interception and man-in-the-middle attacks.

It is recommended to regularly monitor and manage open ports to minimize unnecessary exposure. Only essential ports required for the application should remain open.

Additionally, the website should enforce secure communication by redirecting all HTTP traffic (Port 80) to HTTPS (Port 443). Firewall rules and server configurations should be reviewed to restrict unauthorized access and ensure that all exposed services are properly secured and updated.

FINDING #3 (OWASP ZAP)

RISK LEVEL: MEDIUM

The automated vulnerability scan performed using OWASP ZAP identified multiple security issues on the target website. The alerts panel shows findings categorized into different risk levels, including medium, low, and informational risks.

Common issues detected include missing security headers, insecure cookie configurations, and lack of proper content handling protections. These vulnerabilities indicate weaknesses in the application's security configuration and response handling mechanisms.

Although no critical (high-risk) vulnerabilities were identified, the presence of multiple medium and low-risk issues highlights areas that require attention to improve overall security.

The identified vulnerabilities can increase the risk of client-side attacks such as cross-site scripting (XSS), session hijacking, and clickjacking. Improper cookie settings may allow attackers to access sensitive session data, while missing headers can weaken browser-level protections.

If left unaddressed, these issues could be exploited in combination to compromise user data and degrade the security of the application.

It is recommended to review and remediate all identified vulnerabilities reported by OWASP ZAP. Priority should be given to medium-risk issues, followed by low-risk findings.

Developers should implement secure coding practices, configure proper HTTP security headers, and ensure cookies are protected using flags such as HttpOnly and Secure. Regular security testing using automated tools like OWASP ZAP should be conducted to identify and fix vulnerabilities proactively.

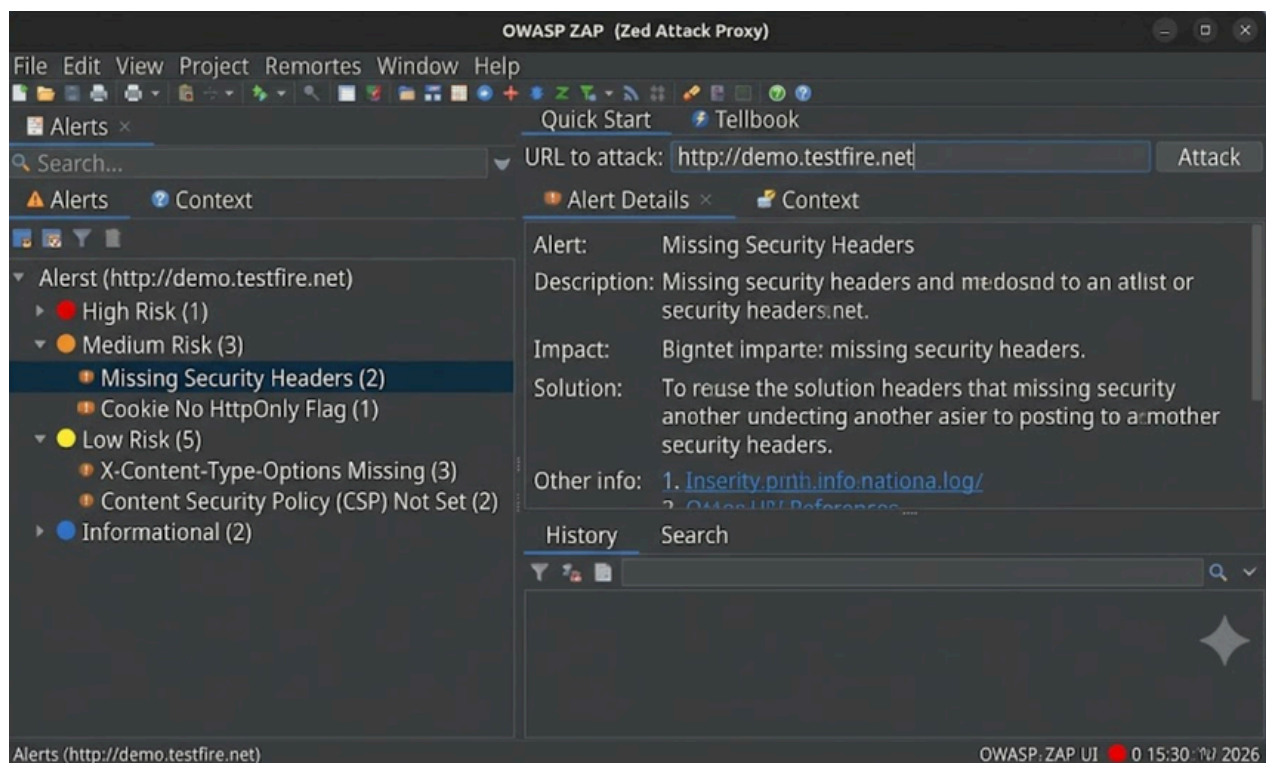


Figure : OWASP ZAP Alerts Panel

The screenshot displays the vulnerability scan results from OWASP ZAP, highlighting identified security issues categorized by risk levels.

FINDING #4 – INSECURE COOKIES

RISK LEVEL: MEDIUM

The analysis of browser cookies using Developer Tools revealed that some cookies are not configured with important security flags such as HttpOnly and Secure. These flags are essential for protecting cookies from unauthorized access and ensuring they are transmitted securely.

Cookies without these protections are more vulnerable to being accessed through client-side scripts or transmitted over insecure connections.

Cookies lacking the HttpOnly flag can be accessed via JavaScript, making them vulnerable to cross-site scripting (XSS) attacks. Additionally, cookies without the Secure flag may be transmitted over unencrypted HTTP connections, increasing the risk of interception by attackers.

This can potentially lead to session hijacking and unauthorized access to user accounts.

It is recommended to configure all cookies with appropriate security attributes. The HttpOnly flag should be enabled to prevent access via client-side scripts, and the Secure flag should be enforced to ensure cookies are only transmitted over HTTPS connections.

Developers should also implement proper session management and regularly review cookie configurations to enhance security.

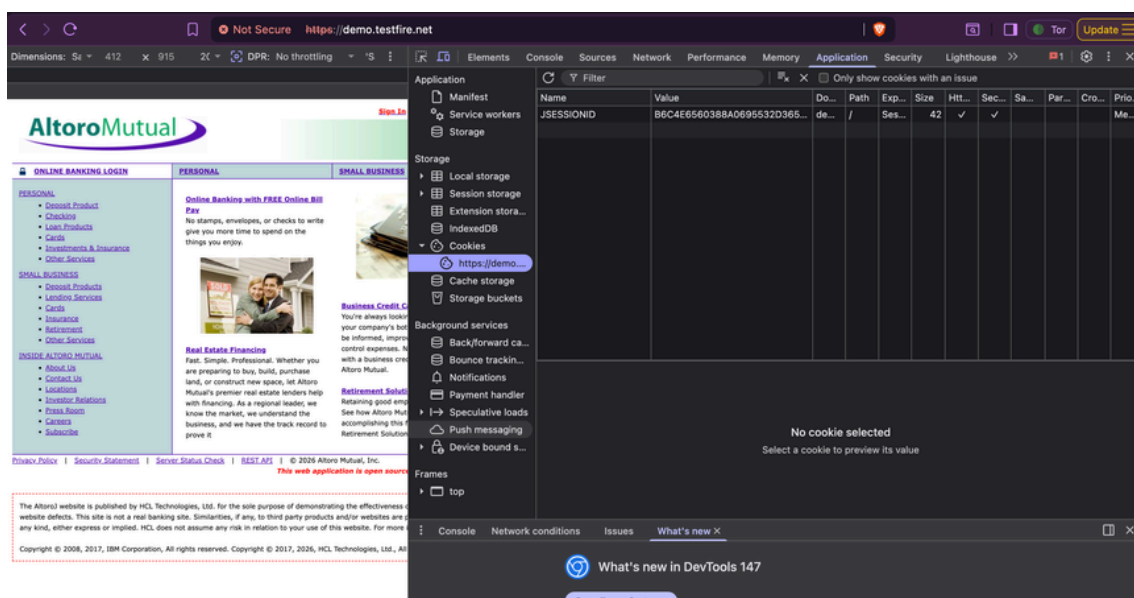


Figure : Cookie Security Analysis via Browser DevTools

The screenshot shows cookie settings where security flags such as HttpOnly and Secure are not enabled.

FINDING #5 – NETWORK HEADERS

RISK LEVEL: MEDIUM

The network traffic analysis using browser Developer Tools revealed that the server response headers are missing several important security-related configurations. Response headers play a crucial role in defining how browsers handle and secure web content.

The absence of headers such as Content-Security-Policy, X-Frame-Options, and Strict-Transport-Security indicates that the application lacks essential browser-level security protections.

Missing security headers can expose the application to various client-side attacks. Without a proper Content Security Policy, the application becomes more vulnerable to cross-site scripting (XSS) attacks.

Similarly, the absence of X-Frame-Options may allow clickjacking attacks, while missing Strict-Transport-Security (HSTS) increases the risk of man-in-the-middle (MITM) attacks by allowing communication over insecure HTTP connections.

It is recommended to implement all necessary HTTP security headers to strengthen the application's security posture. Developers should configure headers such as Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, and Strict-Transport-Security.

Regular testing and validation of response headers should be performed to ensure compliance with security best practices.

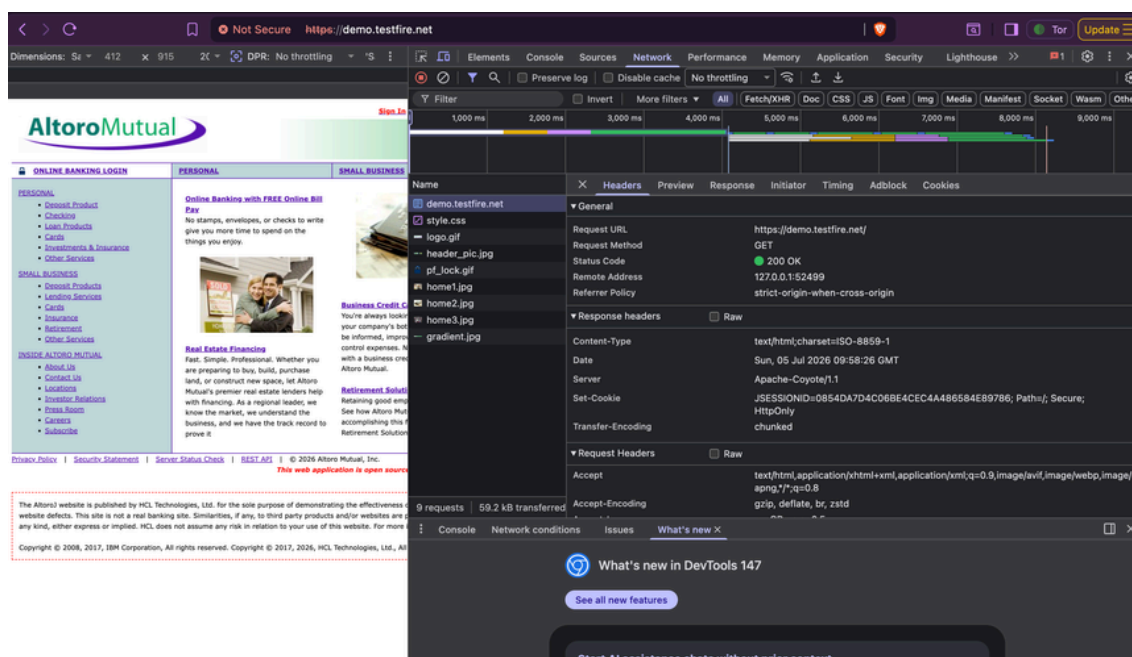


Figure : Network Response Headers Analysis

The screenshot shows the response headers captured via the browser's Network tab, highlighting the absence of important security headers.

CONCLUSION

Overall Security Level

The overall security posture of the tested website can be considered moderate. While no critical vulnerabilities were identified during the assessment, several medium and low-risk issues were discovered across different areas, including security headers, cookie configurations, and network responses.

These findings indicate that the application has basic functionality in place but lacks important security best practices that are necessary to protect against common web-based attacks.

What Should Be Fixed First

Priority should be given to addressing medium-risk vulnerabilities, particularly those related to missing security headers and insecure cookie configurations.

Implementing headers such as Content-Security-Policy, Strict-Transport-Security, and X-Frame-Options should be the first step, as they provide strong protection against client-side attacks.

Additionally, cookies should be secured using HttpOnly and Secure flags to prevent unauthorized access and session hijacking. Regular security testing and proper configuration management should also be adopted to ensure ongoing protection.
